

# Informe de Auditoría de Seguridad

Sistema Analizado: Localhost

Fecha de generación: 2026-02-09 12:02:49

Versión del motor: 1.0

Clasificación: CONFIDENCIAL

Auditoría automatizada · Red Team · Hardening · CIS Benchmark

# Índice

---

1. Resumen de la Auditoría
2. Hallazgos
3. Remediaciones Detalladas
4. Playbooks de Seguridad
5. Conclusión Técnica

# Resumen de la Auditoría

Este informe resume los hallazgos detectados durante el análisis automatizado de seguridad.

| Severidad | Recuento |
|-----------|----------|
| Crítica   | 1        |
| Alta      | 5        |
| Media     | 4        |
| Baja      | 1        |
| Info      | 0        |
| Total     | 11       |

Las secciones posteriores detallan los hallazgos, su impacto técnico, indicadores asociados y recomendaciones completas de remediación.

## Hallazgos

### CHK-SSH-5 — SSH Banner no configurado

**Referencia CIS:** 5.1.5

**Severidad:** MEDIA

**Explicación breve:**

Un banner legal advierte sobre uso no autorizado.

**Evidencia:**

No se encontró parámetro Banner

**Recomendación:**

Añadir Banner /etc/issue.net

## CHK-SSH-6 — Ciphers inseguros detectados

**Referencia CIS:** 5.1.6

**Severidad:** ALTA

**Explicación breve:**

Los cifrados CBC son débiles frente a ataques conocidos.

**Evidencia:**

```
Se encontró el cipher inseguro: aes128-cbc
```

**Recomendación:**

```
Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

## CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

**Referencia CIS:** 5.1.8

**Severidad:** ALTA

**Explicación breve:**

Evita tunelización no autorizada.

**Evidencia:**

```
Línea 126: AllowTcpForwarding yes
```

**Recomendación:**

```
AllowTcpForwarding no
```

## CHK-SSH-20 — PermitRootLogin debe estar en 'no'

**Referencia CIS:** 5.1.20

**Severidad:** CRITICA

**Explicación breve:**

Evita accesos directos al usuario root.

**Evidencia:**

```
Línea 135: PermitRootLogin yes
```

**Recomendación:**

```
PermitRootLogin no
```

## CHK-SSH-22 — UsePAM debe estar en 'yes'

**Referencia CIS:** 5.1.22

**Severidad:** MEDIA

**Explicación breve:**

PAM añade controles avanzados de autenticación.

**Evidencia:**

```
Línea 147: UsePAM no
```

**Recomendación:**

```
UsePAM yes
```

## CHK-SSH-12 — KexAlgorithms inseguros detectados

**Referencia CIS:** 5.1.12

**Severidad:** ALTA

**Explicación breve:**

Usar Algoritmos Kex inseguros puedes exponer las conexiones a posibles ataques 'Man In The Middle'

**Evidencia:**

```
Se encontró el KexAlgorithm inseguro: diffie-hellman-group1-sha1
```

**Recomendación:**

```
KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256
```

## UFW-301-HARDENING — Regla ALLOW sin LIMIT

**Referencia CIS:** Recomendación Adicional de ConfigHunter

**Severidad:** MEDIA

**Explicación breve:**

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos. Se recomienda modificar este parametro si no es estrictamente necesario

**Evidencia:**

```
8080          ALLOW IN    Anywhere
```

**Recomendación:**

```
ufw limit 8080/tcp
```

## UFW-302-HARDENING — Regla demasiado permisiva (ANY/ANY)

**Referencia CIS:** Recomendación Adicional de ConfigHunter

**Severidad:** ALTA

### Explicación breve:

Permitir tráfico desde Anywhere viola las políticas de control de acceso para mantener segura la máquina. Se recomienda modificar este parámetro si no es estrictamente necesario.

### Evidencia:

|      |          |          |
|------|----------|----------|
| 8080 | ALLOW IN | Anywhere |
|------|----------|----------|

### Recomendación:

Restringir la regla a IPs específicas.

## UFW-301-HARDENING — Regla ALLOW sin LIMIT

**Referencia CIS:** Recomendación Adicional de ConfigHunter

**Severidad:** MEDIA

### Explicación breve:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos. Se recomienda modificar este parametro si no es estrictamente necesario

### Evidencia:

|           |          |               |
|-----------|----------|---------------|
| 8080 (v6) | ALLOW IN | Anywhere (v6) |
|-----------|----------|---------------|

### Recomendación:

```
ufw limit 8080/tcp
```

## UFW-302-HARDENING — Regla demasiado permisiva (ANY/ANY)

**Referencia CIS:** Recomendación Adicional de ConfigHunter

**Severidad:** ALTA

### Explicación breve:

Permitir tráfico desde Anywhere viola las políticas de control de acceso para mantener segura la máquina. Se recomienda modificar este parámetro si no es estrictamente necesario.

### Evidencia:

|           |          |               |
|-----------|----------|---------------|
| 8080 (v6) | ALLOW IN | Anywhere (v6) |
|-----------|----------|---------------|

### Recomendación:

Restringir la regla a IPs específicas.

## UFW-403-HARDENING — Reglas sin especificar protocolo (tcp/udp)

**Referencia CIS:** Recomendación Adicional de ConfigHunter

**Severidad:** BAJA

### Explicación breve:

No definir el protocolo impide aplicar políticas precisas.

### Evidencia:

|               |          |                     |          |
|---------------|----------|---------------------|----------|
| 8080          | ALLOW IN | Anywhere; 8080 (v6) | ALLOW IN |
| Anywhere (v6) |          |                     |          |

### Recomendación:

```
ufw allow | limit <port> / tcp|udp
```

## Remediaciones Detalladas

Esta sección proporciona instrucciones extensas y completas para corregir cada hallazgo, incluyendo impacto técnico, pasos detallados y validaciones posteriores.



## CHK-SSH-5 — SSH Banner no configurado

### Impacto técnico:

Un banner legal advierte sobre uso no autorizado.

### Pasos de remediación:

1. Editar o crear el banner:  
`sudo nano /etc/issue.net`
2. Añadir texto legal corporativo.
3. Configurar SSH para usarlo:  
`sudo nano /etc/ssh/sshd_config`  
`Banner /etc/issue.net`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep banner --> Debe aparecer: banner /etc/issue.net
```

## CHK-SSH-6 — Ciphers inseguros detectados

### Impacto técnico:

Los cifrados CBC son débiles frente a ataques conocidos.

### Pasos de remediación:

1. Editar archivo SSH:  
`sudo nano /etc/ssh/sshd_config`
2. Localizar:  
se encontró el cipher inseguro: aes128-cbc
3. Aplicar la recomendación:  
`Ciphers aes256-ctr,aes192-ctr,aes128-ctr`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep ciphers --> Debe aparecer: Ciphers aes256-ctr,aes192-ctr,aes128-ctr
```

## CHK-SSH-8 — AllowTcpForwarding debe estar en 'no'

### Impacto técnico:

Evita tunelización no autorizada.

### Pasos de remediación:

1. Editar archivo SSH:  
`sudo nano /etc/ssh/sshd_config`
2. Localizar:  
línea 126: `allowtcpforwarding yes`
3. Aplicar la recomendación:  
`AllowTcpForwarding no`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep allowtcpforwarding --> Debe aparecer: AllowTcpForwarding no
```

## CHK-SSH-20 — PermitRootLogin debe estar en 'no'

### Impacto técnico:

Evita accesos directos al usuario root.

### Pasos de remediación:

1. Editar archivo SSH:  
`sudo nano /etc/ssh/sshd_config`
2. Localizar:  
línea 135: `permitrootlogin yes`
3. Aplicar la recomendación:  
`PermitRootLogin no`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep permitrootlogin --> Debe aparecer: PermitRootLogin no
```

## CHK-SSH-22 — UsePAM debe estar en 'yes'

### Impacto técnico:

PAM añade controles avanzados de autenticación.

### Pasos de remediación:

1. Editar archivo SSH:  
`sudo nano /etc/ssh/sshd_config`
2. Localizar:  
línea 147: `usepam no`
3. Aplicar la recomendación:  
`UsePAM yes`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep usepam --> Debe aparecer: UsePAM yes
```

## CHK-SSH-12 — KexAlgorithms inseguros detectados

### Impacto técnico:

Usar Algoritmos Kex inseguros puedes exponer las conexiones a posibles ataques 'Man In The Middle'

### Pasos de remediación:

1. Editar archivo SSH:  
`sudo nano /etc/ssh/sshd_config`
2. Localizar:  
se encontró el kexalgorithm inseguro: `diffie-hellman-group1-sha1`
3. Aplicar la recomendación:  
`KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256`
4. Recargar SSH:  
`sudo systemctl restart sshd`

### Validación posterior:

```
sudo sshd -T | grep kexalgorithms --> Debe aparecer: KexAlgorithms ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256
```

## UFW-301-HARDENING — Regla ALLOW sin LIMIT

### Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos. Se recomienda modificar este parametro si no es estrictamente necesario

### Pasos de remediación:

```
1. Convertir ALLOW en LIMIT:
sudo ufw delete <número_regla>
sudo ufw limit 8080/tcp
```

### Validación posterior:

```
sudo ufw status verbose | grep -E "^8080(/tcp|udp)?\s" --> La regla debe aparecer como LIMIT para el puerto 8080.
```

## UFW-302-HARDENING — Regla demasiado permisiva (ANY/ANY)

### Impacto técnico:

Permitir tráfico desde Anywhere viola las políticas de control de acceso para mantener segura la máquina. Se recomienda modificar este parámetro si no es estrictamente necesario.

### Pasos de remediación:

```
1. Eliminar regla demasiado permisiva:
sudo ufw delete <número_regla>

2. Aplicar reglas restringidas:
sudo ufw allow from <IP_segura> to any port 8080
```

### Validación posterior:

```
sudo ufw status verbose | grep 'Anywhere' --> No debe aparecer ningún origen 'Anywhere'.
```

## UFW-301-HARDENING — Regla ALLOW sin LIMIT

### Impacto técnico:

Las reglas ALLOW facilitan ataques de fuerza bruta mientras que LIMIT protege contra DoS y accesos repetidos. Se recomienda modificar este parametro si no es estrictamente necesario

### Pasos de remediación:

```
1. Convertir ALLOW en LIMIT:
sudo ufw delete <número_regla>
sudo ufw limit 8080/tcp
```

### Validación posterior:

```
sudo ufw status verbose | grep -E "^8080(/tcp|udp)?\s" --> La regla debe aparecer como LIMIT para el puerto 8080.
```

## UFW-302-HARDENING — Regla demasiado permisiva (ANY/ANY)

### Impacto técnico:

Permitir tráfico desde Anywhere viola las políticas de control de acceso para mantener segura la máquina. Se recomienda modificar este parámetro si no es estrictamente necesario.

### Pasos de remediación:

1. Eliminar regla demasiado permisiva:  
`sudo ufw delete <número_regla>`
2. Aplicar reglas restringidas:  
`sudo ufw allow from <IP_segura> to any port 8080`

### Validación posterior:

```
sudo ufw status verbose | grep 'Anywhere' --> No debe aparecer ningún origen 'Anywhere'.
```

## UFW-403-HARDENING — Reglas sin especificar protocolo (tcp/udp)

### Impacto técnico:

No definir el protocolo impide aplicar políticas precisas.

### Pasos de remediación:

1. Reglas sin protocolo detectadas:  

|      |          |                     |          |               |
|------|----------|---------------------|----------|---------------|
| 8080 | allow in | anywhere; 8080 (v6) | allow in | anywhere (v6) |
|------|----------|---------------------|----------|---------------|
2. Recrear especificando tcp/udp:  
`sudo ufw allow 8080/tcp`

### Validación posterior:

```
sudo ufw status verbose | grep -E "^8080(/tcp|/udp)?\s" --> Las reglas deben mostrar el protocolo explícitamente.
```

## Conclusión Técnica

El análisis realizado ha permitido identificar configuraciones inseguras, servicios expuestos y parámetros críticos que requieren remediación prioritaria. La combinación de hallazgos indica un riesgo operativo significativo si no se implementan las acciones de mitigación proporcionadas.

Se recomienda priorizar las remediaciones de severidad **Crítica** y **Alta**, ya que representan rutas directas de compromiso del sistema. Una vez implementadas las correcciones, puede ejecutarse un nuevo análisis para verificar la efectividad del endurecimiento.

Este informe proporciona una base sólida para el hardening continuo del entorno, permitiendo avanzar hacia un sistema alineado con CIS Benchmark y mejores prácticas de la industria.